

Risk-Aware Compliance-as-Code

A Machine Learning (ML)-Gated Secure CI/CD Pipeline for Software Supply Chain Integrity

Public Repo: github.com/castroaj/risk-aware-supply-chain-security

*Every time your team ships software, one question **SHOULD** be answered:*

Every time your team ships software, one question SHOULD be answered:

"How do we know this is safe to deploy?"

Software Attacks and Demands Have Shifted

The threat landscape has changed and so have the rules.

Software Attacks and Demands Have Shifted

45%

of global organizations will face attacks on their software supply chains

Gartner, Top Cybersecurity Statistics 2025

Software Attacks and Demands Have Shifted

18,000

organizations affected by a single supply chain breach

SolarWinds, 2020 - including U.S. federal agencies and Fortune 500 companies

The Regulatory Response

The Regulatory Response

Executive Order 14028

Every software component must be inventoried. No Software Bill of Materials (SBOM) could mean no federal contract.

The Regulatory Response

Executive Order 14028

Every software component must be inventoried. No SBOM could mean no federal contract.

NIST SP 800-218 (SSDF)

Deployment decisions must be documented and auditable. Who decided. Why. On what basis.

The Regulatory Response

Executive Order 14028

Every software component must be inventoried. No SBOM could mean no federal contract.

NIST SP 800-218 (SSDF)

Deployment decisions must be documented and auditable. Who decided. Why. On what basis.

Securities and Exchange Commission (SEC) Cybersecurity Disclosure Rules

A supply chain breach is now a reportable financial event. Boards are on the hook.

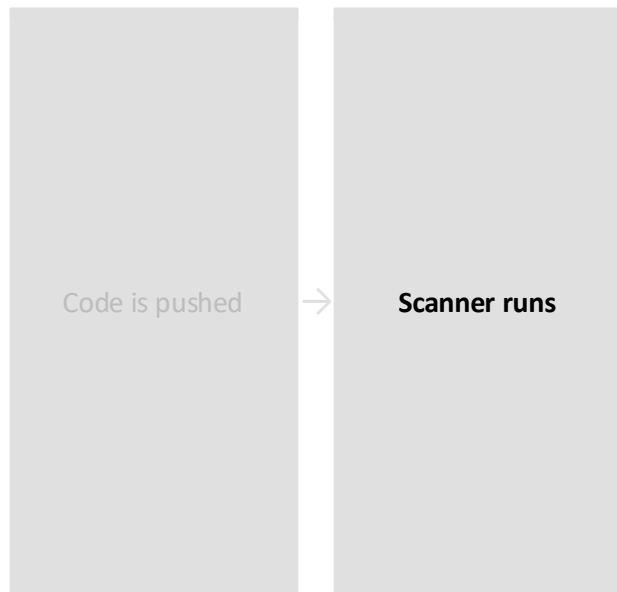
The Gap in Risk Translation Today



Code is pushed

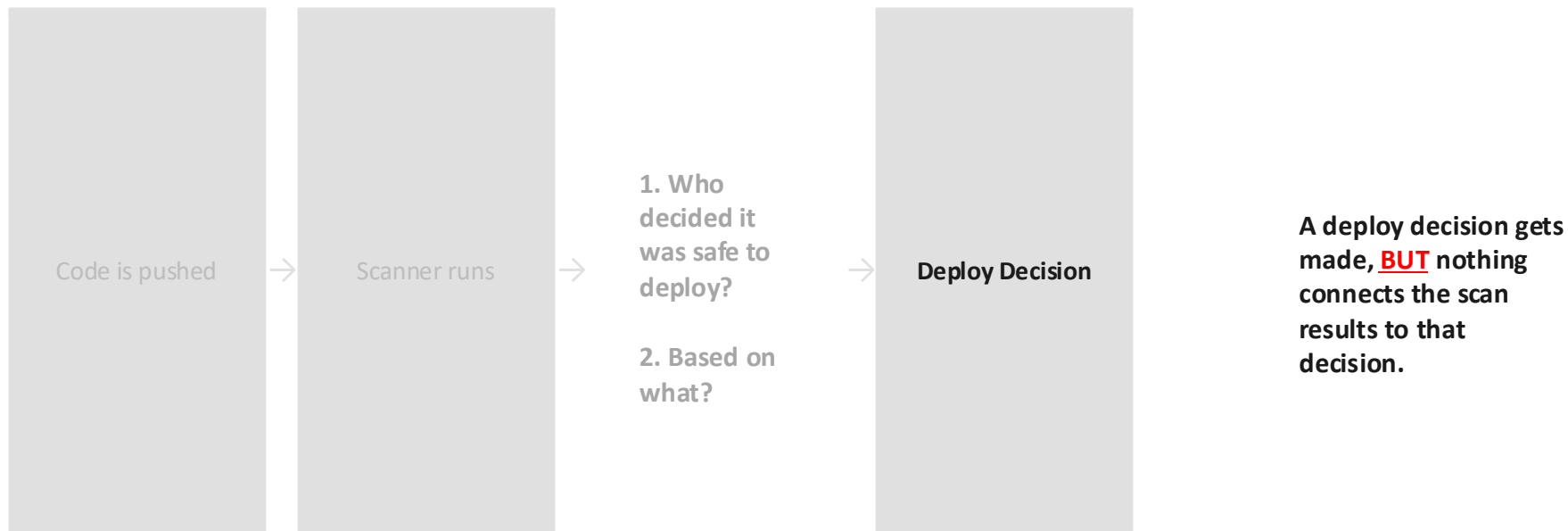
**A container image is
built and queued for
deployment.**

The Gap in Risk Translation Today



A vulnerability scanner checks every component in the image against known Critical Vulnerability and Exposure (CVE) databases.

The Gap in Risk Translation Today



The Gap in Risk Translation Today



1. Reads the scan
2. Makes the risk decision
3. Logs why and what

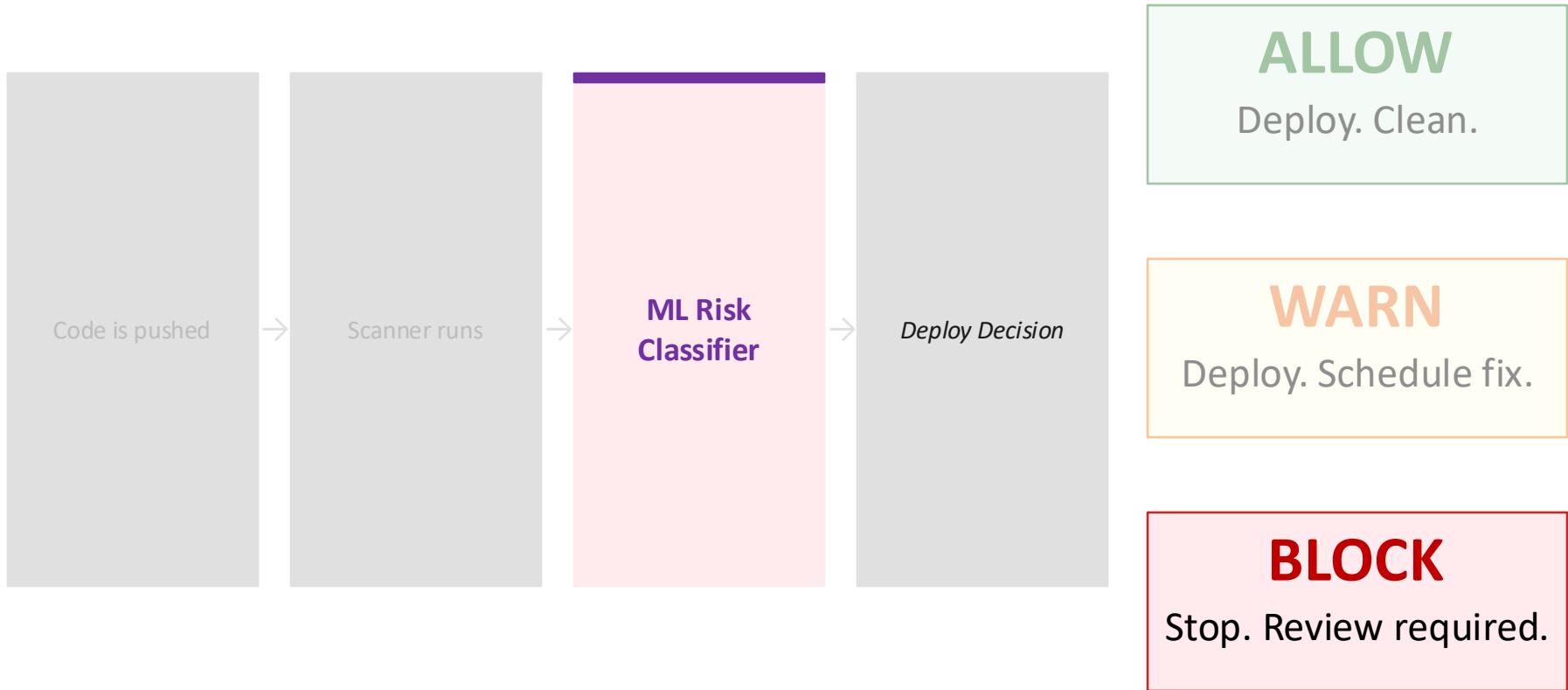
Three Deployment Decisions



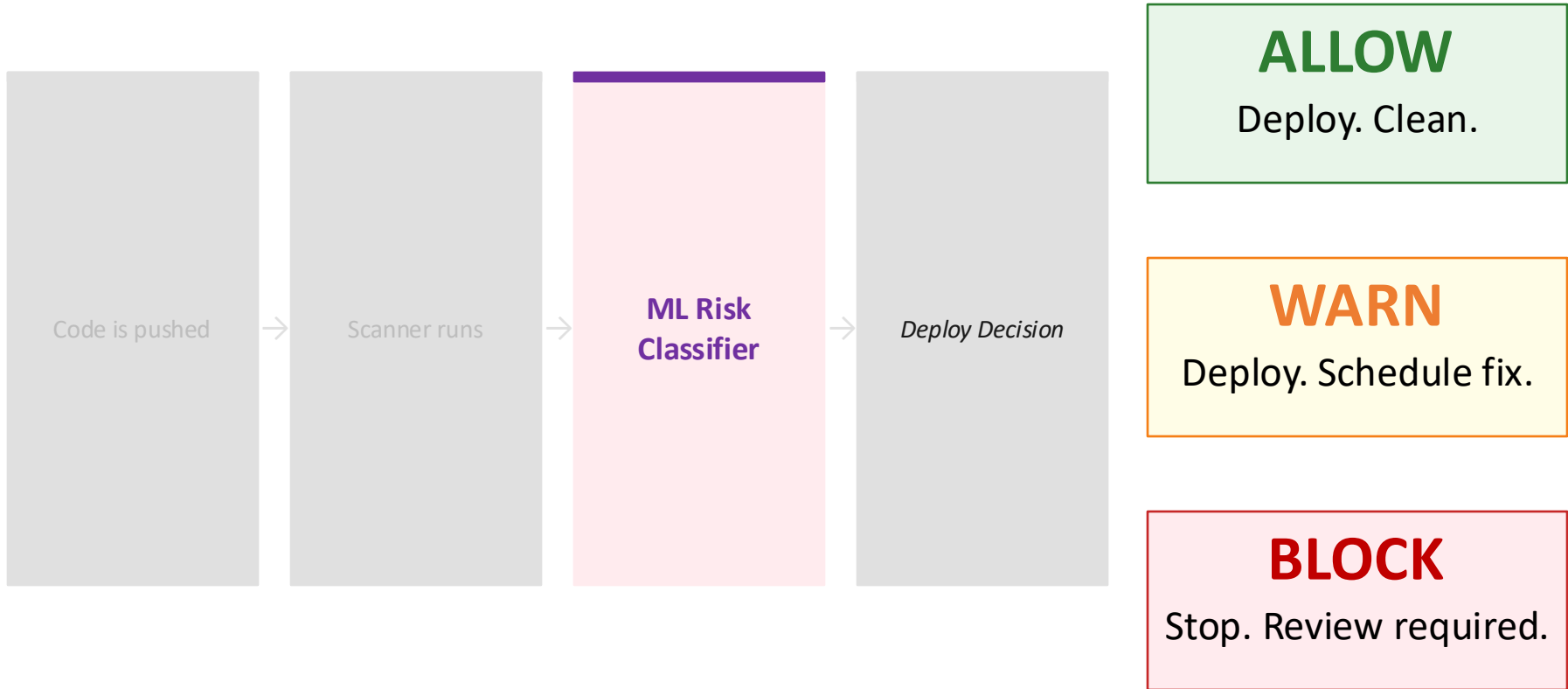
Three Deployment Decisions



Three Deployment Decisions



Three Deployment Decisions



Three Principles Behind Every Decision

01 Explainability

Every decision has a traceable reason. A security engineer can read exactly which feature values triggered a BLOCK - without reverse-engineering a model.

Three Principles Behind Every Decision

01 Explainability - Every decision has a traceable reason. A security engineer c...

02 Context over counts

Density matters, not just raw numbers. 30 critical CVEs in a 400-component image is a different risk from 30 in a 15-component image.

Three Principles Behind Every Decision

01 Explainability - Every decision has a traceable reason. A security engineer c...

02 Context over counts - Density matters, not just raw numbers. 30 critical CVEs in a...

03 Automation with a human backstop

The system handles routine decisions automatically. When uncertain, it escalates. When it blocks, a human can override but that override goes into the log with a reason.

Four Stages of the Model

1

Scan

2

Extract

3

Classify

4

Enforce & Log

Four Stages of the Model

1

Scan

2

Extract

3

Classify

4

Enforce & Log

Four Stages of the Model

1

Scan

2

Extract

3

Classify

4

Enforce & Log

Four Stages of the Model

1

Scan

2

Extract

3

Classify

4

Enforce & Log

Stage 1 - Trivy Scan

1 2 3 4
Scan Extract Classify Enforce & Log



01

Pull the image

Docker pulls the container image from the registry.

```
terminal
$ docker pull python:3.9-slim
3.9-slim: Pulling from library/python
1f8b5ae: Pull complete
2c4c5f62: Pull complete
Digest: sha256:4a9f3...
Status: Downloaded newer image
```

Stage 1 - Trivy Scan

1 2 3 4
Scan Extract Classify Enforce & Log



02

Deep scan

Trivy inspects every layer against three CVE databases.

```
terminal

$ trivy image --format cyclonedx python:3.9-slim

[INFO] Detecting vulnerabilities...
[INFO] Trivy DB: 2026-05-09

python:3.9-slim (debian 11.7)
=====
Total: 47  CRITICAL: 3  HIGH: 12

CVE-2023-4911  libglibc  CRITICAL  9.8
CVE-2023-29491 ncurses   HIGH      7.8
CVE-2023-2975 openssl  HIGH      7.4
```

Stage 1 - Trivy Scan

- 1 Scan
- 2 Extract
- 3 Classify
- 4 Enforce & Log



03

Generate SBOM

Trivy outputs a CycloneDX JSON file - every component, every version, and every known CVE in one structured artifact.

```
sbom.json

{
  "bomFormat": "CycloneDX",
  "components": [
    {
      "name": "libglibc",
      "version": "2.31-13",
      "vulnerabilities": [{
        "id": "CVE-2023-4911",
        "ratings": [{ "score": 9.8,
                     "severity": "critical" }]
      }]
    }
  ]
}
```

Stage 1 - Trivy Scan

1 2 3 4
Scan Extract Classify Enforce & Log



04

Store as artifact

The SBOM is saved permanently in GitHub Actions. Any future threat can be checked against it without re-running the pipeline.

```
workflow.yml

# GitHub Actions workflow
- name: Upload SBOM
  uses: actions/upload-artifact@v3
  with:
    name: sbom-${{ github.sha }}
    path: sbom.json
    retention-days: 90

✓ sbom-a3f92c1.json archived
✓ Audit record written
✓ Stage 2 triggered
```

Deep Dive into the ML Risk Classifier

An interpretable, logged deployment decision.

8 Risk Inputs

Total components

Total vulnerabilities

Critical CVE count

High CVE count

Exploitable count (CVSS ≥ 7)

Highest severity score

MITRE Top 25 CWE Count

Deep Dive into the ML Risk Classifier

1 2 3 4
Scan Extract **Classify** Enforce & Log



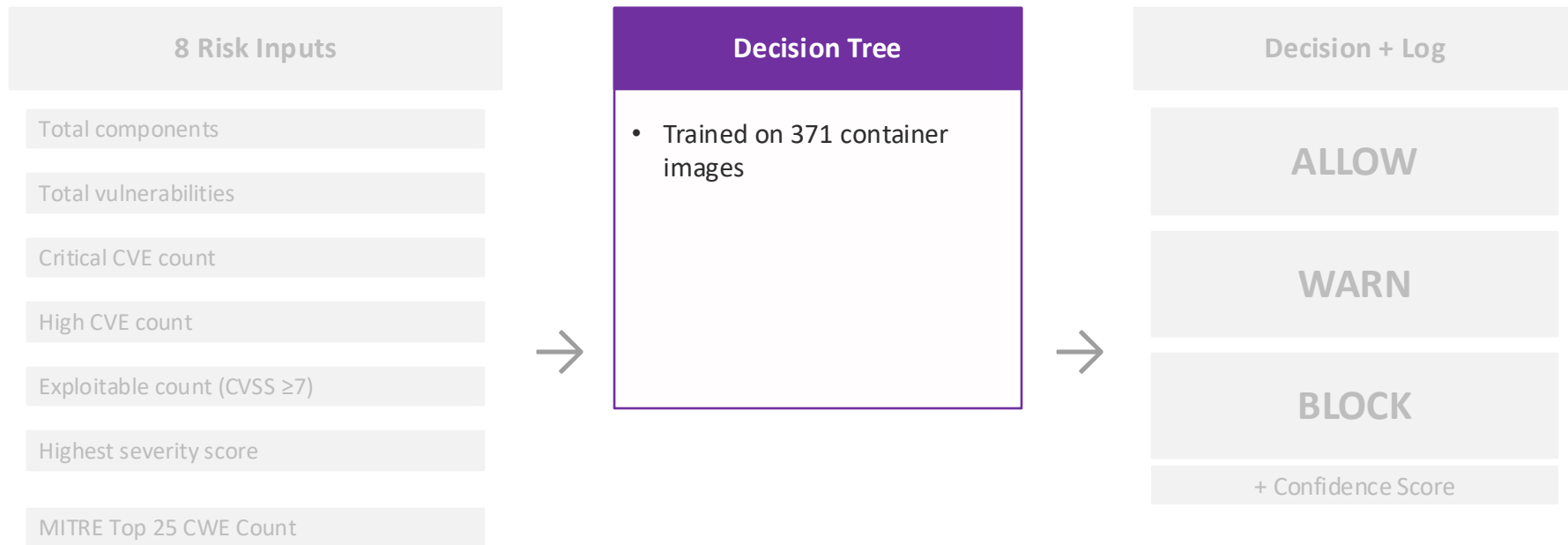
Deep Dive into the ML Risk Classifier

1 Scan 2 Extract 3 **Classify** 4 Enforce & Log



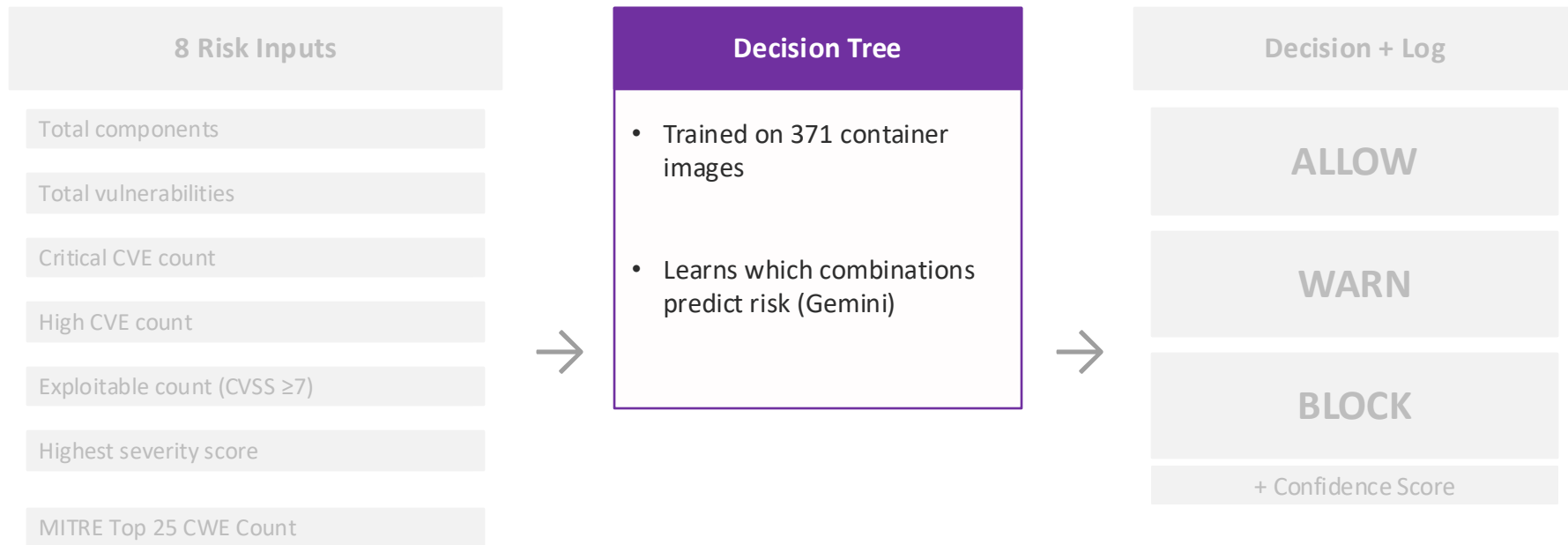
Deep Dive into the ML Risk Classifier

1 Scan 2 Extract 3 **Classify** 4 Enforce & Log



Deep Dive into the ML Risk Classifier

1 Scan 2 Extract 3 **Classify** 4 Enforce & Log



Deep Dive into the ML Risk Classifier

1 Scan 2 Extract 3 **Classify** 4 Enforce & Log

8 Risk Inputs

Total components

Total vulnerabilities

Critical CVE count

High CVE count

Exploitable count (CVSS ≥ 7)

Highest severity score

MITRE Top 25 CWE Count

Decision Tree

- Trained on 371 container images
- Learns which combinations predict risk (Gemini)

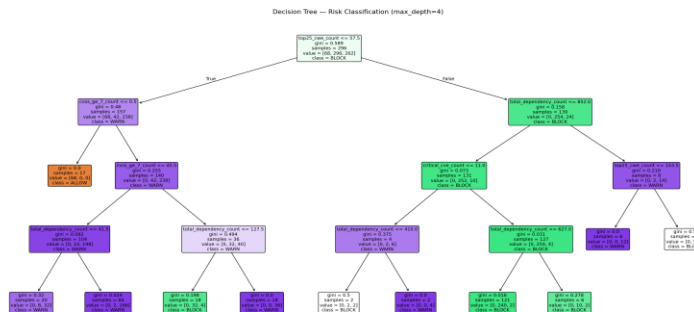
Decision + Log

ALLOW

WARN

BLOCK

+ Confidence Score



ML Risk Classifier

Enforce & Log

8 Risk Inputs

Total components

Total vulnerabilities

Critical CVE count

High CVE count

Exploitable count (CVSS ≥ 7)

Highest severity score

MITRE Top 25 CWE Count

Decision Tree

- Trained on 371 container images
- Learns which combinations predict risk (Gemini)

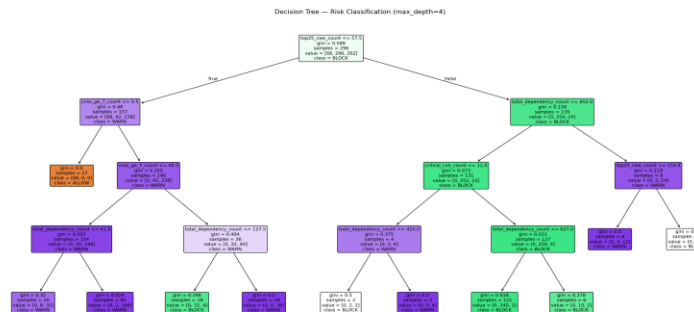
Decision + Log

ALLOW

WARN

BLOCK

+ Confidence Score



Why This Architecture Wins at Scale

LLM reasoning + Decision Tree = ML Risk Classifier

Decision latency

< 1 sec

No GPU. No API call at runtime.
Pure CPU decision tree inference.

Inference cost

~\$0

LLM runs once at training time.
Production inference is free.

Scales to any velocity

∞ pipelines

Stateless. Runs in every
pipeline simultaneously.

Why This Architecture Wins at Scale

LLM reasoning + Decision Tree = ML Risk Classifier

Decision latency

< 1 sec

No GPU. No API call at runtime.
Pure CPU decision tree inference.

Inference cost

~\$0

LLM runs once at training time.
Production inference is free.

Scales to any velocity

∞ pipelines

Stateless. Runs in every
pipeline simultaneously.

Why This Architecture Wins at Scale

LLM reasoning + Decision Tree = ML Risk Classifier

Decision latency

< 1 sec

No GPU. No API call at runtime.
Pure CPU decision tree inference.

Inference cost

~\$0

LLM runs once at training time.
Production inference is free.

Scales to any velocity

∞ pipelines

Stateless. Runs in every
pipeline simultaneously.

ML Risk Classifier Final Performance

92%

Overall accuracy

On unseen test images

ML Risk Classifier Final Performance

92%

Overall accuracy

On unseen test images

91%

WARN correctly
identified

The hardest class

ML Risk Classifier Final Performance

92%

Overall accuracy

On unseen test images

91%

WARN correctly
identified

The hardest class

92%

BLOCK correctly
identified

No dangerous misses to ALLOW

ML Risk Classifier Final Performance

92%

Overall accuracy

On unseen test images

91%

WARN correctly
identified

The hardest class

92%

BLOCK correctly
identified

No dangerous misses to ALLOW

0.002

Train/test gap

Generalizes to new data

v0.0.7 - Final Performance

92%

Overall accuracy

On unseen test images

91%

WARN correctly
identified

The hardest class

92%

BLOCK correctly
identified

No dangerous misses to ALLOW

0.002

Train/test gap

Generalizes to new data

The remaining 8% is handled - not ignored

Conclusion

Mission Accomplished.

ML Risk Classifier Secure CI/CD Pipeline for Software Supply Chain
Integrity

Three Known Limitations

01

Labels are still proxies

Trained on AI-generated labels,
not expert reviewed incident data

02

Doesn't see your code

Third-party components only.
Application vulnerabilities not
covered.

03

**Vulnerability does not imply
exploitability**

A security flaw does not automatically
enable an attacker to cause harm.

Three Known Limitations

01

Labels are still proxies

Trained on AI-generated labels,
not real incident data.

02

Doesn't see your code

Third-party components only.
Application vulnerabilities not
covered.

03

Vulnerability does not imply
exploitability

A security flaw does not automatically
enable an attacker to cause harm.

Three Known Limitations

01

Labels are still proxies

Trained on AI-generated labels,
not real incident data.

02

Doesn't see your code

Third-party components only.
Application vulnerabilities not
covered.

03

**Vulnerability does not imply
exploitability**

A security flaw does not automatically
enable an attacker to cause harm.

Future - State Recommendations

Immediate

Real incident data for training labels

Near-Term

Add time-based signals + application code analysis

Future - State Recommendations

Immediate

Real incident data for training labels

Near-Term

Add time-based signals + application code analysis

AI Usage

Tool	Provider	Used For	Notes
ChatGPT	OpenAI	Project planning & research	Used to structure our project plan, research supply chain security concepts, and draft initial research questions.
Google Gemini 2.5 Flash	Google	Training data labeling	Generated ALLOW / WARN / BLOCK labels for 371 training images based on SBOM features. Used for labeling only - never at inference time.
Claude Pro	Anthropic	Slide content generation	Used via Claude Code integration to help generate and refine presentation slide content throughout the project.

All AI-generated content was reviewed and verified by the team. Final decisions, analysis, and conclusions are our own.

Risk-Aware Compliance-as-Code

An ML-gated deployment classifier. Interpretable. Auditable. Automated.

Ayra Islam · Alexander Castro · Derrick Buabeng · Joseph Jnr A Yeboah

CYSE 690 -DL1/003 · George Mason University

Questions?

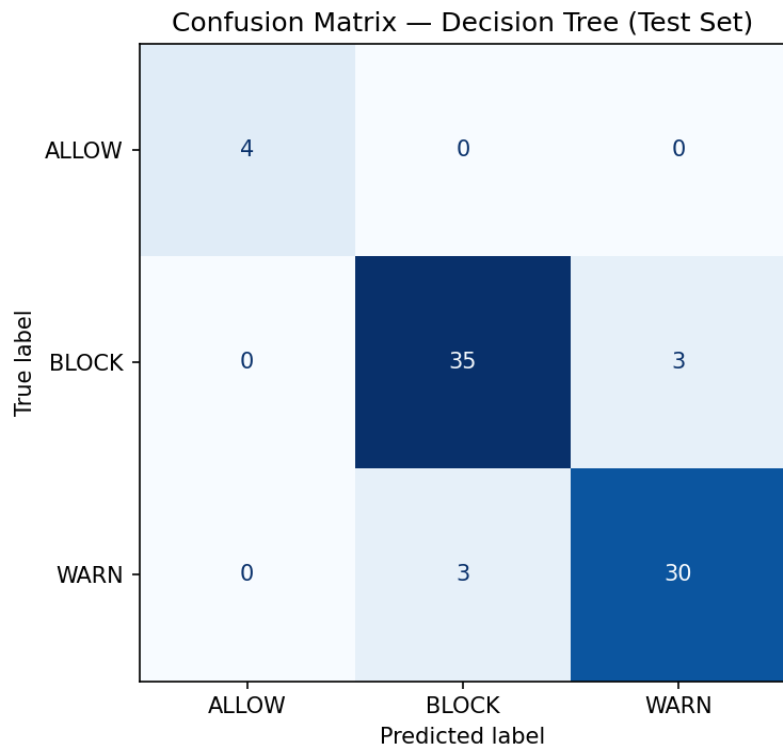
github.com/castroaj/risk-aware-supply-chain-security

Appendix

CYSE 690 -DL1/003 · George Mason University

Confusion Matrix - v0.0.7 (LLM Density Labels)

Test set: 75 images · Labeling: Gemini density-ratio prompt · Test accuracy: 92.00%



ALLOW: 4/4 correct

All 4 ALLOW test images classified correctly. Very small class - LLM v3 correctly identified that truly clean images are rare in our dataset.

BLOCK: 35/38 correct

3 BLOCK→WARN misses. These are the operationally risky misclassifications - confidence escalation policy is designed to catch these at the boundary.

WARN: 30/33 correct

3 WARN→BLOCK misses (conservative direction). In a security gate, WARN→BLOCK is the safer failure mode vs. BLOCK→WARN.

CV-test gap: 0.002

Near-zero gap. Model generalizes reliably to unseen data. This is the strongest generalization result in the series.

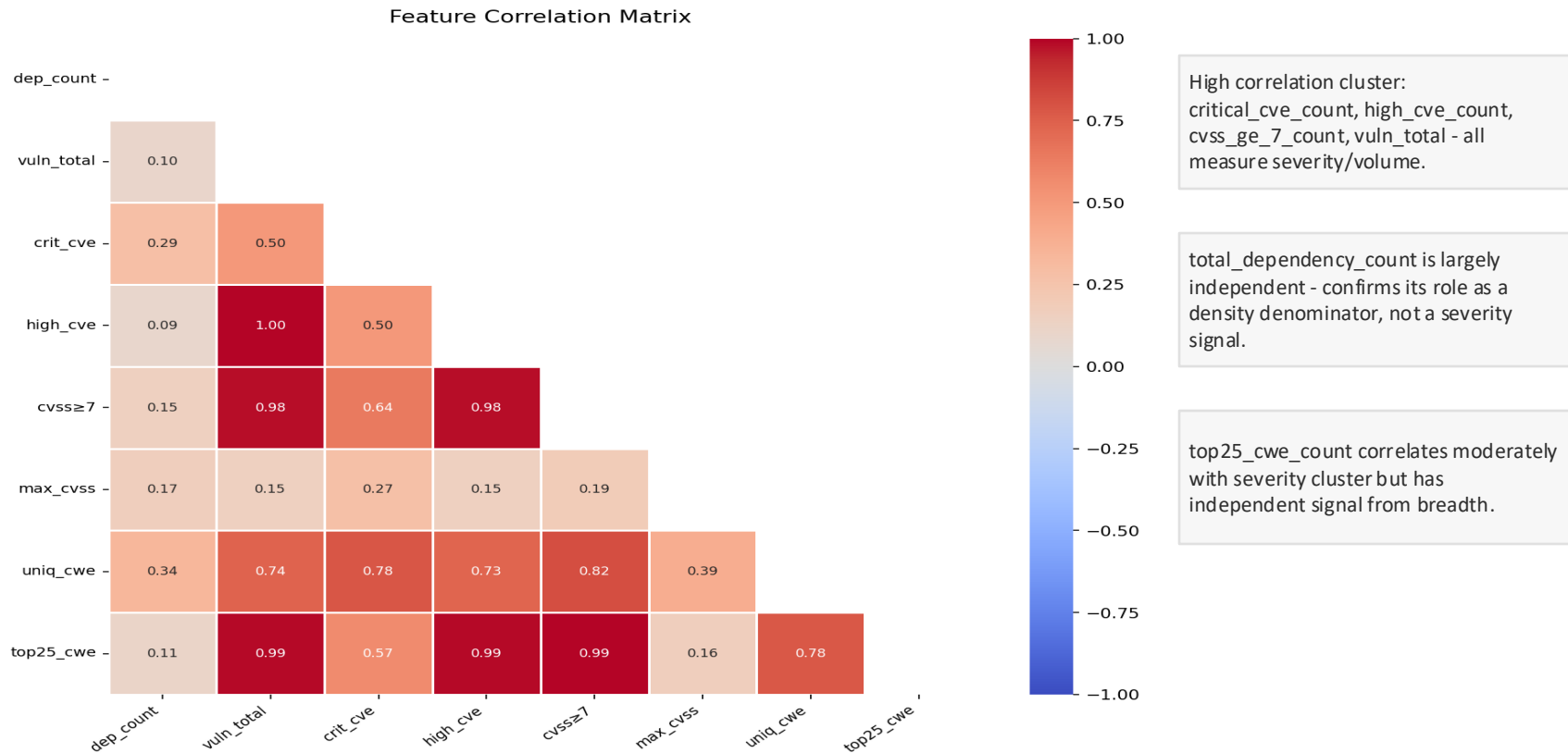
Feature Reference - All 8 Inputs

Extracted by sbom_extractor.py from CycloneDX JSON output of Trivy:

Feature	Type	Description	Risk Axis	v0.0.7 Importance
total_dependency_count	Integer	Total SBOM components	Attack surface / density denominator	~33%
vuln_total	Integer	All vulnerabilities across all components	Volume	~0%
critical_cve_count	Integer	CVEs rated CRITICAL (max across all CVE DBs)	Severity	~14%
high_cve_count	Integer	CVEs rated HIGH severity	Severity	~0%
cvss_ge_7_count	Integer	Vulnerabilities with CVSS score ≥ 7.0	Exploitability	~3%
max_cvss	Float	Highest single CVSS score in the scan	Severity ceiling	~0%
unique_cwe_count	Integer	Distinct CWE weakness type categories	Weakness breadth	~2%
top25_cwe_count	Integer	Vulns matching MITRE CWE Top 25 (2025)	Weaponized breadth	~48%

Feature Correlation Matrix - v0.0.7

Pearson correlation between features in the v0.0.7 training set:



Pipeline Technical Specification

Component	Tool	Detail
Vulnerability Scanner	Trivy (Aqua Security)	<code>docker run aquasec/trivy image --format cyclonedx <image></code>
SBOM Format	CycloneDX JSON v1.4	Chosen over SPDX: security-first design, vulnerability component native to spec
Feature Extractor	<code>sbom_extractor.py</code> (custom)	Parses CycloneDX JSON, normalizes CVSS across NVD/GHSA/OSV, outputs CSV feature row
ML Classifier	scikit-learn <code>DecisionTreeClassifier</code>	Serialized as <code>.pkl</code> - stateless, no external dependencies at inference time
LLM Labeler	Google Gemini 2.5 Flash	Used for training label generation only - not at inference time
Pipeline Host	GitHub Actions	Integrated as PR check; gates deploy job via job output: <code>decision=BLOCK</code>
Audit Log	JSON file / artifact	Timestamped entry per build: image, decision, confidence, all 8 features, model version